



Midterm Project Demonstrations

CEN429 Secure Programming — Week 7

Asst. Prof. Dr. Uğur CORUH · 30.10.2026

This Week: Midterm Project Demonstrations (RAP1)

- No lecture; each team **submits its interim report** and **demonstrates its application**
- RAP1 = **60%** of the midterm · Quiz-1 = **40%** → $\text{Grade_Midterm} = 0.6 \cdot \text{RAP1} + 0.4 \cdot \text{QUIZ1}$
- Detailed rubric: project guide · order, timing, submission time: in class
-  Late submissions are not accepted

Midterm Rubric: Five Criteria

Criterion	LO	Guide
Security analysis	1	S2 · S3 interface table · S4 threat/attacker model
Data security	2	S5 asset list · S7 shell matrix
C/C++ hardening and RASP	3	S9 (basic) · S10
Project management	5	S13 process, SBOM · GitHub repo and plan
Interim report	7	All midterm sections

Evidence = the relevant guide section + code + test output; show at least one control for every threat.

How the Rubric Is Read — Diagram

Rubrik nasıl okunur?

her puan satırı bir kanıta bağlanır



Kanıtı olmayan satır puanlanmaz — 13. haftanın uyum matrisi mantığı burada da geçerli.

Which Sections in the Interim Report?

Complete	Draft / brief / plan
S0 cover · S2 overview · S3 architecture · S4 threat model	S1 scope (draft) · S5 assets (draft)
S7 data security · S10 RASP · S13 process	S9 hardening (basic) · S12 reporting (brief)
	S16 testing (plan) · S17 compliance matrix (draft)

Left for the final: S6 · S8 · S11 · S14 · S15

RAP1 Submission — Diagram

RAP1 (vize) teslimi: ne bekleniyor?

ürünün ilk yarısı + kılavuzun ilk bölümleri

S2 · Ürün ve mimari

bileşenler, arayüzler, güven sınırları

S3 · Arayüzler

her arayüz için doğrulama

S4 · Tehdit modeli

STRIDE + saldırı ağacı

S5 · Varlık listesi

her varlık: konum, koruma şeması

Temel korumalar

AEAD, güvenli silme, girdi doğrulama

RAP1 = 0,7 · vize notu. Kalan 0,3 Quiz-1'den gelir.

Preparation Checklist

Week	What you should be able to show
1	Repo + plan · S2 · S3 interface table · S4 STRIDE + attack tree · S5 draft (C/I/I+)
2	Every threat → CWE + CVSS v3.1 vector
3	S7 algorithm/key/binding · shell matrix · CSPRNG · AEAD verification
4	S9 protection table · CERT findings · ASan+UBSan · fuzz result
5	SBOM + scan · input validation table
6	S10 RASP inventory · response policy · a bypass attempt

Suggested Demonstration Flow

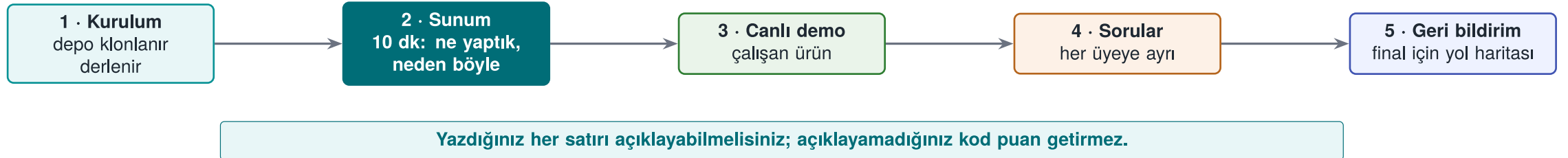
1. **Product and architecture** (S2–S3, ~2 min): one diagram, trust boundaries
2. **Threats and assets** (S4–S5): the three most critical threats, a control for each
3. **Live demonstration**: at least one control **working live** (e.g. encrypted data, signature verification, a RASP trigger)
— backup video + commands ready
4. **Evidence**: protection table, sanitizer/fuzz, SBOM — command + output
5. **Remaining risk and plan**: what remains before the final? (honest analysis earns points)

For every control: **What does it protect?** · **How was it built?** · **How was it proven?**

Demonstration Day Flow — Diagram

Gösterim günü akışı

toplam 20 dakika · takımın HER üyesi konuşur



Demo checklist

What you open and show, in this order:

1. The **home page** of the local site (`9-open-site-...` , on `http://localhost`).
2. **Each report page**: tests, code coverage, documentation coverage (Windows and Linux).
3. The **API docs**.
4. The `release/` **folder** listing.
5. **Run the app** from the release archive.
6. The **GitHub Release page** of your private repository (the instructor is a collaborator).

Sample Questions

- Which flow crossing a trust boundary is the riskiest?
- How long does this asset stay unencrypted in memory, and where is it wiped?
- Where does the key come from, where does it live, when is it deleted? Can the nonce repeat?
- Which compiler protection is turned off, and why?
- What happens when a RASP check fails?
- Does the SBOM contain a vulnerable component? Are you affected?
- What are your three most critical assets, their C/I/I+ labels, and their lifecycle?
- Which control addresses a given threat, and how was it verified? (threat → control → evidence)
- What is your remaining risk, and why is it acceptable? (answer honestly and with justification)

Common Mistakes

Mistake	Why is it a problem?
Guide and code are inconsistent	One of the most serious findings
"Secure" claimed without evidence	Not scored
Keys/logs/code missing from the asset list	What is not in the list is not protected
Threat table from general knowledge	Project-specific threats get missed
Unrehearsed demonstration	Time is wasted
Real password/key/personal data in the repo	A serious security mistake; values must be synthetic
Live demo crashes with no backup / remaining-risk section left empty	Looks like a lack of preparation and honest analysis

Common Mistakes — Diagram

Gösterimde sık yapılan hatalar

değerlendirici kanıt arar, iddia değil

YAPMAYIN

slaytta kod okumak
“çalışıyor” deyip göstermemek
tek kişinin konuşması
kanıtsız “güvenli” iddiası

YAPIN

çalışan demoyu göstermek
kararın GEREKÇESİNİ anlatmak
ölçüm/kanıt sunmak
sınırları dürüstçe söylemek

“Şunu yapamadık, nedeni şu” demek, olmayan bir şeyi var göstermekten iyidir.

Academic Integrity

- Uncredited code/text, work from outside the team, fabricated results **are not acceptable**
- Every submitted line must be explainable
- Any team member should be able to present their own section; anyone may be asked a question

After the Demonstration

- Write the feedback as a **finding list** (finding · severity · fix · date) → a small model of Week 12
- Final sections: S6 · S8 · S11 · S14 · S15 · S16 results · S17

A demonstration is a presentation of **evidence**: every claim should be backed by a document, a test, or live output.

Next Week

Week 8 — Midterm Exam Week: Quiz-1

- Scope: weeks 1–6
- Study guide and sample questions: [Week 8 page](#)